

(c) Narrativa explicativa del marco GQM + PRAGMATIC CTEM

El ejercicio de CTEM a escala nacional corre siempre el riesgo de convertirse en una feria de números: superficies de ataque, vulnerabilidades, SLAs, incidentes y demás fauna estadística compiten por captar la atención de decisores que, con frecuencia, sólo quieren saber si el país va a seguir funcionando mañana. El marco GQM + PRAGMATIC está pensado para introducir un poco de orden en ese zoológico.

GQM nos obliga a empezar por donde casi nunca empezamos: los objetivos. No “qué podemos medir”, sino “qué queremos lograr”. En el contexto de CTEM nacional, esto pasa por reducir exposición sistémica, mejorar remediación, aumentar resiliencia y demostrar alineamiento normativo. Una vez claros esos objetivos, las preguntas fluyen con una naturalidad que sorprenderá a quienes han pasado años discutiendo sobre qué versión de CVSS usar.

Las preguntas de nivel nacional –¿cuántos activos críticos están bajo CTEM?, ¿cuántas rutas de ataque explotables siguen abiertas?, ¿qué velocidad de remediación tenemos?– preparan el escenario para el momento incómodo: ¿qué métricas necesitamos para responderlas? Ahí entran M1.1, M2.1, M3.1 y compañía, que traducen los grandes propósitos en números concretos, recogidos desde plataformas CTEM, inventarios, sistemas de tickets y reportes de incidentes.

Pero no basta con tener métricas; hay que saber si son buenas métricas. Ahí entra PRAGMATIC, que funciona como un filtro de calidad sin demasiada compasión. Una métrica que no es predictiva, ni accionable, ni oportuna, y encima sale cara, puede ser muy bonita en un informe, pero no debería condicionar decisiones de país. El objetivo es ir podando indicadores decorativos hasta quedarnos con un conjunto reducido que puntúe razonablemente alto en los nueve criterios.

Los indicadores sobre rutas de ataque explotables (M2.1), por ejemplo, son conceptualmente magníficos: dicen cosas duras sobre la realidad adversarial. Sin embargo, su puntuación en Independiente o Rentable puede ser baja si el país no dispone de capacidades BAS y red team suficientes. En cambio, métricas como el porcentaje de entidades que integran CTEM en sus informes regulatorios (M6.1) son increíblemente baratas de obtener y políticamente muy jugosas, aunque dirán poco sobre el número concreto de puertos abiertos.

La matriz PRAGMATIC no pretende descalificar métricas difíciles; más bien ayuda a decidir dónde merece la pena invertir para que esas métricas mejoren su precisión, oportunidad y rentabilidad. Es perfectamente legítimo aceptar que, en una primera fase, se priorizarán métricas muy PRAGMATIC (M6.1, M3.1) y se reservarán otras más ambiciosas (M2.1, M4.1) para cuando el ecosistema madure.

La gracia del enfoque GQM + PRAGMATIC es que también se puede aplicar dentro de cada organización. El mismo hilo que va de ON1 a M1.1 podría aplicarse de “reducir la exposición de la red hospitalaria autonómica” a “porcentaje de hospitales con descubrimiento continuo de superficie de ataque”. El resultado es un entramado coherente de objetivos, preguntas y métricas que se puede recorrer hacia arriba (de un puerto raro en un firewall a una gráfica en un consejo de administración) y hacia abajo (de una directriz política a una tarea en un backlog de remediación).

En resumen, este marco no pretende inventar nuevos números, sino organizar los ya existentes de manera que dejen de ser anécdotas técnicas y pasen a ser argumentos de política pública y de gestión estratégica. Con un poco de suerte, dentro de unos años será posible responder, con menos intuición y más datos, a la pregunta que subyace a toda discusión sobre CTEM nacional: “¿Estamos moviendo la aguja donde de verdad importa, o sólo estamos midiendo más cosas?”.